

SL1PCONNECT SAS

Politique de Securite des Systemes d'Information

Version 2.0 - Juin 2026

Champ	Détail
Remplace	PSSI v1.0 - Octobre 2023 (Denis THREADNEEDLE - modèle générique)
Auteur v2	Cabinet SOC externe - Mission appel d'offre ISO 27001
Validation	Victor SLIPMAN (PDG) - Denis THREADNEEDLE (DSI) - Me PAYLOADET (DPO)
Statut	APPROUVE - En vigueur à compter de juin 2025
Classification	Confidentiel - Diffusion restreinte
Révision	Annuelle ou après tout incident P1/P2

Ce document corrige les écarts identifiés lors de l'audit de référence n0 et intègre les exigences ISO 27001:2022, RGPD art.9 et HDS.

B.1 Organisation et responsabilités SSI

La direction de SL1PCONNECT SAS (Victor SLIPMAN, PDG) est garant de la sécurité du système d'information. La mise en œuvre opérationnelle est assurée par Denis THREADNEEDLE (DSI), qui assume temporairement le rôle de RSSI par intérim. Le recrutement d'un RSSI dédié est planifié sous 3 mois (exigence ISO 27001:2022, clause 5.3 - incompatibilité cumul DSI/RSSI).

Rôle	Titulaire	Responsabilités principales
PDG - Garant SSI	Victor SLIPMAN	Approbation PSSI, sponsor ISO 27001, arbitrages budgétaires
DSI / RSSI intérimaire	Denis THREADNEEDLE	Pilotage SSI, validation acces privileges, coordination incidents
DPO externe	Me I. PAYLOADET (JurisFibre)	Conformité RGPD/HDS, notification CNIL, avis traitements DSCP
Admins systèmes	PATCHMAN / STACKSON / VLANSON	Application mesures techniques, gestion accès, surveillance SI
Utilisateurs	Tous collaborateurs	Respect charte SI, signalement anomalies

B.2 Perimetre de la PSSI

La PSSI s'applique à l'ensemble des collaborateurs (CDI, CDD, alternants, stagiaires, prestataires) et couvre la totalité du SI SL1PCONNECT SAS :

- Infrastructure OVH (BOXER-HOST, BRIEF, SENSOR, WATCH, PGSQL-HOST 10.0.1.30) - périmètre critique RGPD art.9
- Serveurs Nice (AD Bender/Roger, DNS Homer/Bart/Marge/Lisa, Rick, Morty, Carolyn, Sage)
- Sites distants : Nice (siège), Paris V XII, Lille, Strasbourg, Bordeaux, Nantes, Lyon, Amsterdam
- Infrastructure industrielle ET/SCADA - Perpignan (réseau isolé - règles spécifiques)
- Atelier Porto (IPsec), DC Marseille LikeSEc (SLA 99,98%), postes de travail (Windows/macOS)
- Prestataires déléguant une partie du SITE : OVH (cloud IoT), LikeSEc (DC), ERP Sage, paiement PCI-DSS

Mise à jour v2 : ajout explicite du perimetre Docker OVH, des sites distants et de l'infrastructure OT Perpignan absents de la v1.0.

B.3 Enjeux et menaces

SL1PCONNECT traite des données de santé (DSCP - art. 9 RGPD) via ses capteurs IoT. Ces données constituent le principal actif à protéger. Trois incidents majeurs ont été documentés depuis 2024 :

Date	Incident	Traitement v1 -> Correction v2
Mars 2024	Injection SQL BRIEF - fuite 150 e-mails clients	Patch ponctuel sans audit global -> Correction préparée statements + WAF déployé
Juillet 2024	Compromission admin BRIEF (mdp 'Sl1p2024') - accès DSCP 48h	Changement mdp sans AIPD RGPD -> Notification CNIL art.33 à effectuer + MFA oblig.
Janvier 2025	Scan massif ports Docker depuis IP russe (OVH alert)	Aucune action -> Firewall OVH durci + SIEM Wazuh déployé + IDS Suricata actif

Menaces prioritaires retenues : exfiltration DSCP (APT41), ransomware (FIN8/Scattered Spider), injection SQL sur BRIEF, compromission AD (credential stuffing), intrusion Docker avec pivot PGSQL-HOST, e-skimming (FIN6).

B.4 Sécurité physique

- Locaux serveurs (Nice) : accès restreint personnel IT autorisé, badge + journalisation, climatisation, UPS (30 min autonomie min.)
- Sauvegardes stockées dans un local distinct du serveur principal - copie hors-site obligatoire (v2 : correction lacune v1 - hors-site non implémenté)
- OVH : sécurité physique sous responsabilité contractuelle OVH (ISO 27001 certifiée) - DPA a signé en priorité
- LikeSEc Marseille : SLA 99,98% - revue contractuelle annuelle
- Reseau OT Perpignan : baies industrielles en accès restreint - liste nominative autorisée

B.5 Gestion des accès

B.5.1 Politique d'accès

Principe du moindre privilège appliqué sans exception. Tout accès est révoqué immédiatement en cas de départ ou changement de fonction. Revue des droits trimestrielle (matrice RACI).

B.5.2 Politique de mots de passe (mise à jour v2)

Type de compte	Long. min.	Complexité	Renouvellement	MFA
Standards	14 cars.	Maj+Min+Chiffre+Special	180 jours	Recommandé
Admin / comptes privilèges	16 car.	Maj+Min+Chiffre+Special	60 jours	OBLIGATOIRE
Accès DSCP (données santé)	16 car.	Maj+Min+Chiffre+Special	60 jours	OBLIGATOIRE
Comptes de service	20 car.	Génère (gestionnaire)	12 mois	N/A - isolé

Blocage après 5 tentatives échouées. Interdiction de réutiliser les 12 derniers mots de passe. Correction v2 : renouvellement passe de 90 à 60 jours pour les comptes privilèges ; MFA étendu.

B.5.3 Comptes à privilèges

- Clés SSH : individuelles, non partagées (pratique de partage v1 INTERDITE), renouvelées tous les 6 mois
- Accès SSH via bastion jump host obligatoire - accès direct serveurs de production interdit
- Double authentification obligatoire pour modifications AD et accès direct PGSQL-HOST

B.5.4 Accès distants

- Tous accès distants via VPN (IPsec ou SSL) - accès direct Internet aux ressources internes INTERDIT
- RustDesk (gestion ERP Sage) remplacé par solution VPN sécurisée - ports any<->LAN INTERDITS
- BYOD refuse - équipements personnels exclus du SI SL1PCONNECT

B.6 Sécurité des postes de travail

- Antivirus/EDR déployé sur tous les postes - signatures mises à jour quotidiennement
- Chiffrement disque obligatoire : BitLocker (Windows) / FileVault (macOS) - postes nomades en priorité
- Verrouillage automatique de session après 5 minutes d'inactivité (v1 : 10 min - réduit)
- Utilisateurs sans droits administrateurs locaux - exception sur validation écrite DSI uniquement
- Supports amovibles (USB) interdits sauf autorisation écrite DSI
- BYOD refuse - aucun équipement personnel dans le SI
- Postes hors support (1 WinXP, 9 Win7) : isolement réseau strict + surveillance renforcée Wazuh - migration sous 6 mois

B.7 Sécurité des serveurs et conteneurs Docker

Cette section est substantiellement revue suite aux écarts constatés lors de l'audit n0 (conteneurs exécutés en root, secrets en clair, logs non centralisés, images non scannées).

B.7.1 Serveurs

- Patchs critiques : sous 72h - importants : sous 7 jours - standards : sous 30 jours
- Tous services inutiles désactivés - audit de configuration base CIS pour chaque OS
- Logs systèmes centralisés vers SIEM Wazuh/ - retention 12 mois minimum

B.7.2 Conteneurs Docker (périmètre OVH - BOXER/BRIEF/SENSOR/WATCH)

- Exécution en utilisateur NON-ROOT OBLIGATOIRE - correction de la pratique actuelle incompatible
- Images Docker scannées avec Trivy avant tout déploiement en production - zero vulnérabilité CRITIQUE tolérée
- Secrets (tokens API, mots de passe BDD) stockés dans gestionnaire de secrets (HashiCorp Vault) - stockage en clair docker-compose.yml INTERDIT
- Chaque conteneur isolé dans son propre réseau Docker dédié - whitelist explicite inter-conteneurs
- Logs de tous les conteneurs centralisés vers SIEM (agent Wazuh)
- Pipeline CI/CD : étape de scan sécurité obligatoire avant déploiement - déploiements vendredi soir INTERDITS

- Revue de code obligatoire sur toutes les PR (fin des auto-approbations) - prepared statements SQL uniquement

B.8 Politique de sauvegarde

Données	Freq.	Rétention locale	Hors-site (v2 - corrigé)	Chiffrement
BDD PostgreSQL (DSCP sante)	Quotidienne	7 jours	30 jours - DC Marseille	AES-256 OBLIG.
BDD MariaDB (clients/boutique)	Quotidienne	7 jours	30 jours	AES-256 OBLIG.
Configurations serveurs	Hebdo	4 semaines	3 mois	AES-256 OBLIG.
Code source (GitHub)	Continue	Illimitée	GitHub - DPA a finaliser	TLS transit
Fichiers (OwnCloud)	Quotidienne	30 jours	15 jours hors-site	AES-256 OBLIG.

Correction v2 : stockage hors-site non implémenté en v1 -> obligatoire. Tests de restauration trimestriels (DSCP) et semestriels (autres) - résultat consigne.

B.9 Securite reseau

B.9.1 Segmentation

Architecture multi-couches obligatoire - les segments suivants sont strictement isolés :

Segment	Périmètre	Règle
DMZ OVH (10.0.1.0/24)	BOXER-HOST, PGSQL-HOST	Internet -> 80/443 uniquement ; DMZ -> LAN interne INTERDIT
LAN OVH (10.0.2.0/24)	FILE-HOST	Zero accès direct Internet - ports spécifiques DMZ whitelist
Réseau Docker	BRIEF, SENSOR, WATCH	Un réseau dédié par conteneur - bridge partage INTERDIT
Reseau OT Perpignan	AS400, Siemens S7, WinXP	Isole du SI bureautique - FW dédié + liste blanche stricte
Réseau IoT capteurs	Produits connectés	Isole du réseau bureautique et des serveurs de prod
Réseau management	Administration équipements	Accès depuis bastion uniquement - jamais exposé WAN
Réseau invités	Visiteurs, partenaires	Internet uniquement - zeroaccess SI interne

B.9.2 Filtrage et contrôle

- Réglage par défaut : DENY ALL - toute ouverture documentée et validée DSI
- Firewall OVH : durcissement configuration par défaut sous 30 jours (v1 : configuration basique non auditée)
- Firewalls Stormshield SN1100 (Nice/Perpignan/Porto/Marseille) : audit + durcissement configuration
- WAF Nginx + ModSecurity + ruleset OWASP devant BOXER-HOST (déployé dans le cadre du SOC)
- Logs firewalls centralises vers SIEM Wazuh - retention 12 mois
- Revue des règles firewall semestrielle

B.10 Gestion des incidents de sécurité

Le processus de gestion des incidents est formalisé dans le document dédié 'SL1PCONNECT - Gestion des Incidents SOC'. Les éléments essentiels sont rappelés ici.

Priorité	Définition	LA détection	LA résolution
P1 - CRITIQUE	Donnees sante exposées, ransomware, compromission AD	15 min	4h (confinement)
P2 - ÉLÈVE	Intrusion détectée, brute force abouti, SQLi exploitée	30 min	24h
P3 - MOYEN	Scan de ports, tentative brute force, anomalie log	2h	72h

Priorité	Définition	LA détection	LA résolution
P4 - FAIBLE	Faux positif SIEM, alerte isolée non confirmée	8h	7 jours

Workflow obligatoire : Detection (SIEM Wazuh/Suricata) -> Qualification (TheHive) -> Confinement -> Investigation (MITRE ATT&CK) -> Eradication -> Clôture/REX

B.10.1 Procédure RGPD art. 33 (notification CNIL)

- Notification CNIL obligatoire dans les 72h après constatation d'un incident impliquant des DSCP à risque élevé
- DPO Me PAYLOADET consulte dans l'heure suivant la détection - aucune communication externe sans validation DPO+PDG
- Information des personnes concernées si risque élevé (art. 34 RGPD)
- Point de vigilance : incident juillet 2024 (accès non autorisés données santé 48h) - analyse rétrospective par DPO requise**

B.11 Sensibilisation et formation

- Onboarding obligatoire : module sécurité + signature charte informatique avant tout accès SI (charte en cours de rédaction - délai : 30 jours)
- Campagnes trimestrielles : phishing simulé, rappels bonnes pratiques, actualités menaces
- Formation spécifique DSCP : obligatoire pour tout collaborateur ayant accès aux données de santé
- Formation ISO 27001 pour équipe IT : certification Lead Implementer objectif 12 mois
- KPI sensibilisation : taux de clic phishing simulé < 5% cible

B.12 Audit et amélioration continue

Contrôle	Fréquence	Responsable
Audit interne SMSI	Annuel	DSI / futur RSSI
Pentest externe périmètre OVH + apps	Annuel	Cabinet externe
Revue droits d'accès (AD/SSH/Docker)	Trimestrielle	DSI + admins
Test restauration sauvegardes DSCP	Trimestriel	Admins systèmes
Revue règles firewall	Semestrielle	Admin réseau
Revue KPI SIEM / indicateurs sécurité	Mensuelle	SOC / DSI
Audit externe ISO 27001 certification	A 12 mois puis annuel	Organisme certifié

KPI cibles : MTTD incidents P1 < 15 min | MTTR P1 < 4h | MFA comptes admin 100% | Patchs critiques sous 72h > 95% | Score conforme ISO 27001 > 80% à 6 mois.

Approbation et historique des versions

Version	Date	Auteur	Principales évolutions
v1.0	Oct. 2023	D. THREADNEEDLE (DSI)	Version initiale - modèle générique - écarts opérationnels multiples
v2.0	Juin 2025	Cabinet SOC externe	Refonte post-audit n0 : Docker/secrets/sauvegardes/MFA/DPA OVH/incidents RGPD/OT Perpignan

Rôle	Nom	Signature	Date
PDG	Victor SLIPMAN	_____	__/__/2025
DSI / RSSI intérimaire	Denis THREADNEEDLE	_____	__/__/2025
DPO externe	Me I. PAYLOADET	_____	__/__/2025